

Aula 2 (Módulo 05) — WPA, WPA2 e WPA3

1. Por que a segurança do Wi-Fi existe

Diferente de uma rede com fio (onde alguém precisa fisicamente plugar um cabo para acessar), qualquer pessoa **dentro do alcance do rádio** pode "ouvir" o tráfego Wi-Fi. Por isso, a segurança de uma rede sem fio depende inteiramente de **criptografia** e **autenticação** bem feitas — sem isso, qualquer vizinho conseguiria ler tudo que passa pela rede.

2. A linha do tempo (do mais fraco ao mais forte)

WEP (Wired Equivalent Privacy) — obsoleto, nunca use

O protocolo de segurança original do Wi-Fi (anos 1990). Tem falhas criptográficas **graves e bem documentadas** — pode ser quebrado em minutos com ferramentas públicas. Se você encontrar uma rede WEP hoje em dia (raro, mas ainda existe em equipamentos muito antigos), trate-a como **sem segurança nenhuma**.

WPA (Wi-Fi Protected Access) — transição, também obsoleto

Criado às pressas para substituir o WEP, usando o protocolo **TKIP**. Foi uma melhoria na época, mas também tem vulnerabilidades conhecidas. Não deve ser usado hoje.

WPA2 — o padrão mais comum até hoje

Introduziu o **AES** (*Advanced Encryption Standard*) — um algoritmo de criptografia robusto, o mesmo usado em inúmeros outros contextos de segurança (inclusive dentro do TLS que vimos no Módulo 03, Aula 7). WPA2 ainda é amplamente usado e, com senha forte, é razoavelmente seguro — mas tem um ponto fraco conhecido: o **4-way handshake**.

O 4-way handshake e o ataque de captura + brute force offline

Quando um dispositivo se conecta a uma rede WPA2-Personal (com senha compartilhada, chamada de **PSK — Pre-Shared Key**), AP e cliente trocam 4 mensagens para provar que ambos conhecem a senha, sem transmiti-la diretamente pelo ar. Um atacante pode **capturar** esse handshake (passivamente, só escutando o tráfego) e depois tentar **quebrar a senha offline**, testando milhões de combinações no próprio computador, sem precisar continuar interagindo com a rede alvo.

Por que importa para segurança: isso é a razão pela qual **senha forte** é tão importante em WPA2 — uma senha curta ou comum pode ser quebrada em tempo viável com esse handshake capturado; uma senha longa e aleatória torna esse ataque impraticável. Também existe uma técnica chamada **deauthentication attack**: o atacante envia frames de "desautenticação" forjados (o Wi-Fi, historicamente, não verifica quem realmente enviou esse frame) para forçar um dispositivo já conectado a se desconectar — e assim capturar o handshake do momento em que ele se reconecta automaticamente, em vez de esperar passivamente. Isso é catalogado no MITRE ATT&CK (matriz ICS/técnicas relacionadas a rede) e é um dos motivos pelos quais o WPA3 (a seguir) foi desenhado para resistir a captura offline.

WPA3 — o padrão atual, mais robusto

Substituí o mecanismo de troca de chave do WPA2 por um protocolo chamado **SAE** (*Simultaneous Authentication of Equals*, também conhecido como "Dragonfly"), que tem uma propriedade importante: **resistência a ataques offline** — mesmo capturando toda a troca de mensagens, um atacante não consegue testar senhas offline da mesma forma que fazia com WPA2. Cada tentativa de adivinhar a senha precisa interagir ativamente com o AP, o que é muito mais lento e detectável. WPA3 também traz **Forward Secrecy** (mesmo que a senha vaze no futuro, tráfego capturado no passado continua protegido) e um modo específico para redes abertas (sem senha) com criptografia individualizada, chamado **Enhanced Open**.

3. Modos Personal vs. Enterprise

Independente da versão (WPA2/WPA3), existem dois modos de operação:

- **Personal (PSK)**: uma única senha compartilhada entre todos os dispositivos — típico de redes domésticas. Ponto fraco: se um dispositivo/pessoa vazar a senha, **todos** precisam trocá-la.
- **Enterprise (802.1X)**: cada usuário/dispositivo autentica com **credenciais próprias**, geralmente contra um servidor **RADIUS** (frequentemente integrado a um Active Directory, que veremos em detalhe no módulo próprio) — típico de redes corporativas. Permite revogar o acesso de **uma pessoa** sem afetar as outras, e dá visibilidade de **quem** exatamente se conectou, não só "alguém que tinha a senha".

Por que importa para segurança: em ambientes corporativos, WPA2/WPA3 **Enterprise** é fortemente preferido sobre Personal justamente pela rastreabilidade individual — que conecta diretamente com o princípio de "saber quem fez o quê" que já vimos repetidamente (usuários, Aula 2 do Módulo 00).

4. Conectando tudo

WEP → quebrado, nunca use
WPA → transição, também obsoleto
WPA2 → AES robusto, mas handshake capturável → depende de senha forte
WPA3 → SAE resistente a captura offline, Forward Secrecy

Personal (PSK) → uma senha para todos; Enterprise (802.1X/RADIUS) →
credencial individual, mais rastreável

5. Exercício de reflexão

No seu roteador (se tiver acesso administrativo), verifique qual protocolo de segurança está configurado (geralmente na tela de configuração do Wi-Fi). Está em WPA2? WPA3? Ainda tem alguma opção WEP habilitada por engano (checagem comum de hardening)? Não é necessário mudar nada agora — o objetivo é só reconhecer a configuração real de uma rede de verdade.

6. Recapitulando

- WEP e WPA são obsoletos e inseguros — não usar.

- WPA2 usa AES (robusto), mas o handshake PSK pode ser capturado e atacado offline — daí a importância de senha forte; deauth attack é usado para forçar captura do handshake.
- WPA3 (SAE) resiste a ataque offline e adiciona Forward Secrecy.
- Enterprise (802.1X/RADIUS) dá credencial individual e rastreabilidade; Personal (PSK) é uma senha única para todos.

Próxima aula (fecha o Módulo 05)

Setup do adaptador AR9271 e monitoramento de tráfego wireless — sempre em laboratório próprio, rede própria ou ambiente explicitamente autorizado.

Fontes recomendadas

- **Wi-Fi Alliance — "Security"**: página oficial explicando WPA2 e WPA3, incluindo SAE. <https://www.wi-fi.org/discover-wi-fi/security>
- **NIST SP 800-97 — "Guide to IEEE 802.11i: Robust Security Networks"**: referência técnica oficial sobre a arquitetura de segurança do Wi-Fi (base do WPA2). <https://csrc.nist.gov/pubs/sp/800/97/final>
- **MITRE ATT&CK — T1557 (Adversary-in-the-Middle)**: categoria de técnica que inclui ataques de interceptação, relevante ao contexto de deauth + captura de handshake. <https://attack.mitre.org/techniques/T1557/>